

1. A security analyst performed a network scan on the target 192.168.1.10 using the Nmap tool. The report identified several open ports, including HTTP (80), SSH (22), and MySQL (3306), along with the operating system and service versions. Analyze the report and explain the security risks associated with the identified services. Discuss how an attacker could exploit these services and recommend suitable security measures to protect the target system.

Introduction

Nmap (Network Mapper) is an open-source network scanning tool used by security professionals to discover hosts, identify open ports, detect running services, determine service versions, and identify operating systems. It helps assess the security posture of a target system.

Scan Results

Target IP: 192.168.1.10

Port	Service	Status
22	SSH	Open
80	HTTP	Open
3306	MySQL	Open

The scan also identifies the operating system and versions of the running services

Security Risks

1. SSH (Port 22)

Purpose:

SSH provides secure remote access to the system.

Security Risks

- Weak or default passwords can be guessed using brute-force attacks.
- Outdated SSH versions may contain vulnerabilities.
- Misconfigured authentication may allow unauthorized access.
- Root login over SSH increases the attack surface.

Possible Attacks

- Password brute-force attack.
- Credential stuffing.
- Exploitation of vulnerable SSH software.

- Unauthorized remote administration.

Security Measures

- Use strong passwords and SSH keys.
 - Disable root login.
 - Enable multi-factor authentication (MFA).
 - Limit login attempts using Fail2Ban.
 - Restrict SSH access with a firewall.
 - Keep the SSH server updated.
-

2. HTTP (Port 80)

Purpose

Provides web services to users.

Security Risks

- Data transmitted over HTTP is unencrypted.
- Vulnerable web applications may allow attacks.
- Information leakage through banners.
- Weak authentication mechanisms.

Possible Attacks

- SQL Injection
- Cross-Site Scripting (XSS)
- Directory Traversal
- Session Hijacking
- Website Defacement

Security Measures

- Use HTTPS instead of HTTP.
- Keep web server software updated.
- Implement Web Application Firewall (WAF).
- Validate all user input.



- Hide server banners.
 - Enable secure session management.
-

3. MySQL (Port 3306)

Purpose

Stores website or application databases.

Security Risks

- Default database credentials.
- Weak passwords.
- Remote database access.
- Unpatched database software.

Possible Attacks

- Unauthorized database access.
- SQL Injection.
- Database theft.
- Data modification or deletion.
- Privilege escalation.

Security Measures

- Disable remote access unless required.
 - Use strong passwords.
 - Apply database updates regularly.
 - Grant minimum required privileges.
 - Encrypt sensitive database information.
 - Enable database auditing and logging.
-

Operating System and Service Version Risks

If the scan reveals:

- Operating system version

- Apache version
- OpenSSH version
- MySQL version

An attacker can:

- Search public vulnerability databases.
 - Find known CVEs.
 - Launch version-specific exploits.
 - Increase the likelihood of successful attacks.
-

Overall Security Recommendations

- Regular vulnerability scanning using Nmap.
 - Apply operating system and software updates.
 - Configure firewalls to block unnecessary ports.
 - Disable unused services.
 - Enable intrusion detection and prevention systems.
 - Monitor logs continuously.
 - Use network segmentation.
 - Perform regular penetration testing.
-

Conclusion

The Nmap report shows three critical services running on the target system. While these services are essential, improper configuration or outdated software can expose the system to attacks. Proper hardening, regular patching, strong authentication, and continuous monitoring significantly reduce security risks.

2. A phishing awareness campaign was conducted for employees of ABC Technologies Pvt. Ltd. Using the GoPhish tool. The report indicates that 40% of employees clicked the phishing link, 20% entered their login credentials, and several users downloaded a malicious attachment. Analyze the report and identify the security weaknesses demonstrated by the employees. Recommend suitable user awareness programs, email security controls, and organizational policies to reduce the risk of successful social engineering attacks.

Introduction

GoPhish is an open-source phishing simulation platform used to evaluate employee awareness of phishing attacks. It helps organizations identify users who are vulnerable to social engineering attacks.

Campaign Results

- 40% clicked the phishing link.
 - 20% entered login credentials.
 - Several employees downloaded a malicious attachment.
-

Security Weaknesses

1. High Click Rate (40%)

This indicates:

- Employees cannot identify phishing emails.
- Users trust suspicious links.
- Poor awareness of email security.

Risk

- Malware infection.
 - Credential theft.
 - Unauthorized system access.
-

2. Credential Submission (20%)

This indicates:

- Employees entered usernames and passwords into fake login pages.
- Lack of verification of website authenticity.
- Poor password security awareness.

Risk

- Account compromise.
- Identity theft.
- Data breaches.



- Privilege escalation.
-

3. Downloading Malicious Attachments

This demonstrates:

- Employees opened unsafe attachments.
- Lack of malware awareness.
- Failure to verify email legitimacy.

Risk

- Ransomware.
 - Trojan infection.
 - Spyware installation.
 - Data theft.
 - Remote access by attackers.
-

How Attackers Exploit These Weaknesses

An attacker may:

- Send fake HR emails.
 - Create fake login pages.
 - Steal employee credentials.
 - Install ransomware.
 - Spread malware across the network.
 - Access confidential business data.
 - Launch Business Email Compromise (BEC) attacks.
-

Recommended User Awareness Programs

Regular Security Awareness Training

- Phishing identification.
- Safe browsing.
- Password security.



- Social engineering techniques.

Simulated Phishing Campaigns

- Conduct monthly phishing simulations.
- Measure employee improvement.
- Provide targeted training.

Password Security Education

- Strong passwords.
- Password managers.
- Multi-factor authentication.

Incident Reporting Training

Employees should immediately report:

- Suspicious emails.
- Unknown attachments.
- Fake login pages.

Recommended Email Security Controls

- Email filtering.
- Anti-spam gateways.
- Anti-malware scanning.
- URL filtering.
- Attachment sandboxing.
- SPF configuration.
- DKIM implementation.
- DMARC enforcement.
- Block executable attachments.
- Email warning banners.

Recommended Organizational Policies



- Mandatory cybersecurity awareness training.
 - Acceptable Use Policy.
 - Password Policy.
 - MFA policy.
 - Incident response policy.
 - Email verification procedures.
 - Regular phishing assessments.
 - Least privilege principle.
-

Conclusion

The GoPhish campaign shows that employees remain vulnerable to phishing attacks. Combining continuous security awareness training, robust email security controls, and strong organizational policies can significantly reduce the risk of successful social engineering attacks.

3. A DNS assessment report generated using the Dig tool shows that the organization's DNS server permits a successful DNS Zone Transfer (AXFR), exposing internal hostnames, mail servers, and DNS records. Analyze the report and explain the security implications of the exposed information. Discuss how attackers could exploit these findings and recommend best practices to secure the DNS infrastructure.

Introduction

The Dig (Domain Information Groper) tool is used to query DNS servers and retrieve DNS records. During the assessment, the DNS server allowed a successful DNS Zone Transfer (AXFR).

Security Implications

The zone transfer exposed:

- Internal hostnames.
- Mail servers.
- DNS records.
- Subdomains.



- Network structure.

This information should normally be accessible only to authorized DNS servers.

How Attackers Can Exploit the Information

An attacker can:

- Map the organization's internal network.
 - Identify mail servers for phishing attacks.
 - Discover hidden systems.
 - Identify VPN or administrative servers.
 - Launch targeted attacks against critical hosts.
 - Gather intelligence for further exploitation.
 - Plan social engineering attacks.
-

Security Risks

- Information disclosure.
 - Increased reconnaissance capabilities.
 - Easier target identification.
 - Higher risk of phishing.
 - Greater attack surface.
 - Faster penetration testing by attackers.
-

Best Practices to Secure DNS Infrastructure

- Disable unauthorized DNS zone transfers.
- Allow AXFR only between trusted secondary DNS servers.
- Use firewall rules to restrict DNS access.
- Enable DNSSEC to protect DNS integrity.
- Regularly patch DNS server software.
- Monitor DNS logs for suspicious activity.
- Remove unnecessary DNS records.

- Use split-horizon DNS for internal and external records.
 - Perform regular DNS security audits.
-

Conclusion

A successful DNS zone transfer exposes valuable network information that attackers can use during reconnaissance. Restricting zone transfers, implementing DNSSEC, monitoring DNS activity, and following DNS security best practices help protect the organization's DNS infrastructure from information leakage and targeted attacks.

